

Pilot-checklista — CVmatchen × Helsingborg AMF

Pilot: Ungdoms-/Kompetensarena · ca 20–40 deltagare · 3–4 handläggare · 3 månader, kostnadsfritt **Uppdaterad: 2026-07-11** (efter nattens PR #16–18 + verifiering mot kod)

Ägare: **[D]** Oliver/du · **[K]** kommun (chef/verksamhet) · **[DSO]** dataskyddsombud · **[J]** jag (kod)

⚠ TESTA FÖRST I MORGONRUNDAN

[] **Exportera en PDF från appen** (CV eller rapport). Lambdan bootar bevisat och samma kod gav perfekta PDF:er (åäö, styling) lokalt, men Chromium-körningen i Vercel-lambdan går bara att slutverifiera med en riktig export efter nattens ESM-migrering (`api/pdf.mjs`). Funkar den inte → säg till, rollback är ett kommando. · **[D]**

🔴 BLOCKERAR pilotstart (innan första riktiga deltagardata)

Juridiskt & organisatoriskt

- [] PUB-avtal signerat av båda parter (du för PathfinderAI, behörig kommunföreträdare för PUA — ej du i SYV-rollen) · **[D]+[K]**
- [] Pilotbeslut fattat + diariefört av kommunen (din chef/verksamhetschef), skilt från den generella bisysslan · **[K]**
- [] DPIA godkänd av DSO · **[DSO]**
- [] Laglig grund för ev. art. 9-uppgifter fastställd · **[DSO]**
- [] Lagringstid fastställd (förslag: radering vid pilotens slut) · **[DSO]**

Tekniskt (test, ej bygge)

- [] Mejl-/OTP-leverans verifierad i skarpt (invite → deltagare via Resend) · **[D]+[J]**
 - [] Invite-kedjan testad end-to-end (bjud in → OTP → CV → uppgift) · **[D]+[J]**
-

✅ KLART — verifierat i koden

Natten (PR #16–18)

- [x] **API-kostnadshärdning** — `chat.js`: modell-whitelist (bara Sonnet 5 + Haiku 4.5), origin-spärr (→ 403), 20 anrop/IP/min + 300/IP/dygn
- [x] **pdf.js** — 6 PDF/IP/min + origin-spärr (var helt oskyddad)
- [x] **Beroende-sårbarheter 23 → 0** — puppeteer-core 25.1 + @sparticuz/chromium 149 (matchat par), Sentry 10
- [x] **CSP skärpt** — `unsafe-eval` borttagen (jsPDF/html2canvas/JSZip verifierade utan violations)
- [x] **PDF-lambdan** flyttad till `api/pdf.mjs` (äktat ESM, löste ERR_REQUIRE_ESM)

Sedan tidigare

- [x] GDPR-radering (`admin_delete_user` + `user_delete_self` , kaskad 13 tabeller + auth + invites)
- [x] AI-samtycke live (versionerat, återkalleligt)
- [x] Bedrock-EU aktiv (AI-data i Frankfurt, ingen lagring/träning)
- [x] Varningstext mot känsliga uppgifter i fritext (art. 9)
- [x] DEMO_MODE av i produktion

- [x] Multi-tenant-isolation (serverside verifyAdmin, deny-by-default)
 - [x] XSS-fixar + OAuth-callback (host-header-whitelist, CSRF-state)
 - [x] SQL-injektion (#15) — UUID-arrays saneras före PostgREST in . (. . .)
 - [x] Rate-limiting på admin-actions (#19) — `_RATE_LIMITS` + 429
 - [x] admin_audit används (#21) — radering/åtgärder loggas
 - [x] **Deltagar-invite validerat** — token + e-post + utgång + konsumtion
 - [x] Bisyssla prövad + godkänd av HR (undertecknat beslut)
 - [x] Matchningsverktyget (404-bugg) fixat
 - [x] a11y: aria-label på alla synliga kontroller
 - [x] Dokument: PUB + DPIA (Helsingborg-specifika), verifieringsrapport, lasttest-script
-

🟡 BÖR fixas (ej blockerande, men klokt före/tidigt i pilot)

- [] **Rotera de två flaggade API-nycklarna** (`SUPABASE_SERVICE_KEY` + `ANTHROPIC_API_KEY`) — ~5 min · **[D]** (#34)
 - [] Döp om `WS_BEARER_TOKEN_BEDROCK` → `AWS_BEARER_TOKEN_BEDROCK` i Vercel · **[D]** (#33)
 - [] **Invite-token som defense-in-depth i handläggare-OAuth** (#9) — i dag gatekeepas handläggare av e-post-allowlist (säkert nog); token valideras ej. Lågt, bör wire:as. · **[J]**
 - [] Fel-svar kan läcka DB-meddelandetext (`JSON.stringify(result.data)` som fallback) — maska (#18) · **[J]**
 - [] E-post-PII i nekad-försök-loggen — verifiera/maska (#17) · **[J]**
 - [] Onboarding-guide för handläggare (första-gångs-vy) (#11) · **[J]**
 - [] Mobil-layout i handläggare-vyn (#12) · **[J]**
 - [] "Skicka om invite"-knapp (#14) + pilot-utgångsbanner (#13) · **[J]**
-

🟡 KAN vänta (efter pilotstart / bred lansering)

- [] `unsafe-inline` i CSP — kräver refaktor av alla inline-handlers · **[J]**
 - [] Full JWT-auth på chat.js — origin-spärren täcker webbläsarvägen; djup auth kräver ändringar i många anropsställen, görs vaket · **[J]**
 - [] Extern penetrationstest (före bred lansering) · **[D]** (Visionsfonden)
 - [] Extern WCAG-audit av hela appen (t.ex. Funka) · **[D]** (Visionsfonden)
 - [] Djup GDPR-audit · **[D/DSO]**
 - [] Statistik-export CSV (#22), pratbubblor (#S4), Capacitor-app (#S3) · **[J]**
-

📅 17 Parallella spår

- [] **Visionsfonden-ansökan** (öppnar sept 2026) — finansierar pentest + WCAG-audit · **[D]** (#S1)
 - [] Effektuppföljning under piloten (deltar/slutför/upplevd nytta) — beslutsunderlag + underlag till Visionsfonden · **[D]+[J]**
-

Exakt: vad återstår för att bli grön?

Bara 5 juridik/DSO-punkter + 2 tester. Ingen kvarvarande *blockerande* kodlucka — deltagarflödet är säkert, kostnader härdade, sårbarheter nollade.

1. **[K]** diariefört pilotbeslut · **[D]/[K]** PUB signerat · **[DSO]** DPIA godkänd
2. **[D]** testa PDF-export (morgonrundan) + rotera nycklar

3. **[D]+[J]** testa invite-kedjan + mejl med ett testkonto

4. Bjud in första riktiga deltagaren. 🚀